

Spearbit Sample Audit Report
Client: Sample DEX
Lead auditor: someone@spearbit

5.1.1 Reentrancy in withdraw allows fund theft

Severity: High Risk

Context

The withdraw function in contracts/Vault.sol:42 calls an external token before updating internal accounting state. An attacker can re-enter withdraw and drain the vault.

Impact

An unprivileged user can drain the entire vault balance in a single transaction by triggering reentrant withdraws.

Recommendation

Apply the checks-effects-interactions pattern: update internal balances before the external token call.

Resolution

Fixed in commit abc12345.